SYMBIOSIS INSTITUTE OF TECHNOLOGY (SIT)

॥ वसुधैव कुटुम्बकम् ॥

Constituent of SYMBIOSIS INTERNATIONAL (DEEMED UNIVERSITY)

Theory CA-2 - Case Study Report - Group 23

Subject: Cyber Security

Topic:

Equifax Data Breach 2017 – A Case Study of Vulnerabilities and CyberSecurity Failure

NAME OF STUDENT	PRN
Prajyot Vedante	23070122163
Rishi Modi	23070122180
Rishi Saxena	23070122181

Faculty Name: Dr. Pooja Bagane, Dr. Jitendra Rajpurohit

Date of Submission: 10 October 2026

ABSTRACT:

The Equifax data breach of 2017 was one of the most significant cyber security incidents involving the exposure of sensitive personal information. Equifax INC. One of the largest consumer credit reporting agencies in the United States, suffered a cyber attack that resulted in unauthorized access to personal information login to at least 145.5 million individuals. The attack was associated with a critical vulnerability in the Apache struts web application framework identified as CVE-2017-5638.

The vulnerability was publicly disclosed by a patches software foundation on March 7, 2017 and a security update was made available on the same day. Equifax received a notification regarding the vulnerability and internally instructed personnel to apply the necessary patch. However, the vulnerable system was not successfully identified at attack subsequently, scan Equifax system identified the vulnerable online dispute portal and exploited the vulnerability to gain an authorised access.

Following the initial compromise attackers were able to access internal systems and databases containing personally identifiable information. The investigation identified weaknesses in vulnerability, identification management, network segmentation, credential protection and security monitoring, fax eventually detected suspicious network traffic in July 2017, and initiated an investigation with the assistance of an external cyber security firm.

In this case study exams, the technical and organisational factors that contributed to the breach analyses the attack sequence, identifies major security failures, evaluate the impact of the incident and discuss the security measures that could reduce the likelihood and impact of similar incidents. The Equifax case demonstrates that cyber security depends not only on identifying vulnerability but also ensuring that security controls are implemented, verified and continuously monitored.

KEYWORDS:

Equifax, Data Breach, Cybersecurity, Apache Struts, CVE-2017-5638, Vulnerability Management, Patch Management, Personally Identifiable Information, Incident Response, Network Security.

1.INTRODUCTION

The increasing dependence of organisations on digital systems has made cybersecurity a critical component of modern business operations. Organisations collect and large amounts of sensitive information, including financial records, personal identify us authentication information and other data that can be exploited by cyber criminals, a successful cyber attack and therefore have consequences extending beyond technical system damage and can result in financial losses, legal actions, reputational, damage, and loss of public trust.

A data breach occurs when unauthorized individuals gain access to information or systems that should be protected such breaches may occur through phishing, malware, stolen credentials, software vulnerabilities, misconfiguration, insider activity, or weaknesses in security control. The severity of a breach depends on the type of attack and quantity of information exposed, as well as the organisation's ability to detect and contain the attack.

Equifax INC is a major consumer credit reporting agency in the United States. The organisation maintains large volumes of consumer information used in credit reporting and related services because of the sensitivity of the information maintained by consumer reporting agencies. Strong cyber security controls are essential to protect consumers from identity theft and financial frauds, the United States Government accountability reported that the 2017 Equifax breach resulted in attackers accessing personal information belonging to at least 145.5 million individuals.

The initial attack vector was a vulnerability in Apache struts, an open source framework used to develop Java web applications. The vulnerability was identified as CVE-2017-5638. The Apache software foundation released a fix on March 7, 2017. The same day, the vulnerability was publicly announced

Equifax received notification of the vulnerability and circulated an internal instruction requiring vulnerable Apache systems to be patched. However, the vulnerable version used by its online dispute portal was not successfully identified. A subsequent security scan also failed to detect the vulnerable system.

On March 10, attackers scan Equifax systems for a newly disclosed vulnerability and discover a vulnerable server associated with the dispute port. Beginning in May, attackers gained unauthorized access and subsequently searched the internal system and database for sensitive information.

The Equifax breach is therefore an important cyber security case study because the incident was not caused by the existence of a software vulnerability. Instead, the scale of the breach resulted

from the combination of an unpack, vulnerability and weaknesses in identification verification, internal access, control monitoring, and data protection.

---

2. LITERATURE REVIEW

2.1 Vulnerability Management

Vulnerability management is a continuous cyber security process through which organisations identify vulnerability access the severity, prioritise, remediation and verify. The vulnerability has been successfully resolved. It is particularly important for internet facing applications because vulnerability in such systems may be directly accessible to attackers.

An effective vulnerability management program depends on accurate knowledge of the organisations, hardware and software assets, without a reliable inventory. Security teams may be unable to determine whether a vulnerable component is present within the environment.

The Equifax incident demonstrates this problem, although the Apache struts vulnerability had been publicly disclosed and a patch was available. The vulnerable component remains present within the online dispute portal. Government investigation subsequently identified weaknesses in Equifax identification and patch-management process.

2.2 Apache Struts and CVE-2017-5638

Apache struts is an open source framework for developing Java Web applications on March 7, 2017 patches software foundation announced a security vulnerability affecting certain versions of Apache struts. The vulnerability was designated as CVE-2017-5638.

The vulnerability was particularly serious because exploitation could allow an attacker to execute commands on an affected system. Apache released fixed versions on the same day. The vulnerability was announced.

The Equifax incident demonstrates the danger associated with critical vulnerability and internet facing applications. Once information about the vulnerability became publicly available. Attackers were able to scan systems and search for vulnerable applications.

2.3 Patch Management

Patch management involves identifying security updates, determining which systems are affected, applying the updates and verifying successful installations. Security policies commonly assigned shorter remediation periods to critical vulnerabilities.

In the Equifax case. The company security team instructed relevant personnel to patch affected batches systems within 48 hours. However, the vulnerable systems were not successfully patched by the federal trade commission, later stating that Equifax failed to follow up to ensure that the patching instructions had been carried out.

The distinction between issuing a patching instruction and verifying success. Remediation is an important lesson from the incident. A cyber security process is only effective if the organisation can demonstrate that the required security control is operated.

2.4 Network Segmentation and Access Control

Network segmentation is used to separate systems and limit communication between different parts of an organisation's infrastructure. It reduces the possibility that compromise of one system will automatically provide access to sensitive databases or other critical resources.

According to the GAO, Equifax identified segmentation as one of the major factors relevant to how attackers were able to gain access to databases containing personally identifiable information.

The incident therefore demonstrates the importance of limiting the privileges and network access available to internet facing applications

2.5 Credential Protection

Credentials are an important security boundary because they provide access to systems and data. If credentials are stored securely, attackers who compromise one system may use the credentials to gain access to additional resources.

The FTC reported that after gaining access to the Equifax network attacks, they found an unsecured file containing administrative credentials, stored in plain tax. These credentials cannot access additional databases.

This illustrates why administrative credentials should be protected using secure storage access, controls, credential rotation and appropriate authentication mechanisms.

2.6 Security Monitoring

Security monitoring is essential for detecting unusual activity within an organisation network. Effective monitoring can identify suspicious authentication, unusual database queries, unexpected network connections and abnormal data transfers.

In the Equifax case and expire digital certificates affecting the organisations ability to inspect networks associated with the compromise environment. This contributed to the attackers remaining undetected for an extended period.

The incident demonstrates that organisations must not only deploy monitoring systems, but also continuously verify that those systems are functioning correctly.

2.7 Incident Response

incident responses is a structured process used by an organisation to identify and investigate contain undercover from a cyber security incident. Effective incident response reduces the time an attack can remain inside a network and limit the potential damage. Equifax detected serious network activity on July 29, 2017 and took the affected web application off-line on July 30, the company subsequently engaged Mandian to conduct a forensic investigation and notify the FBI.

---

3. METHODOLOGY

This study uses qualitative cyber security case study methodology to examine the Equifax breach. The objective is to reconstruct the incident. Identify technical vulnerabilities that enabled initial access. Examine the security failures that allow the attack to expand and evaluate the resulting impact.

Information for the studies obtained primarily from authoritative sources, including the United States, government accountability office, the United States, house of representatives, the federal trade commission, Apache software foundation and cyber security standards and guidelines published by the national Institute of standards and technology.

The analysis was conducted in four stages. *First* chronological reconstruction of the incident was developed using official investigation reports and company disclosures. *The second,* technical attack was analysed from initial reconnaissance through an authorised axis and data extraction. *Third,* the major security control failures, identified, and categorised into management axis control segmentation, monitoring and governance. Finally, the consequences of these failures are evaluated and security recommendations.

The attack was analysed using the following concept sequence:

Reconnaissance → Initial Access → Internal Discovery → Credential Access → Database Access → Data Collection → Exfiltration → Detection → Incident Response

This methodology allows the incident to be examined not only as a technical attack but also as a failure of CS processes and organizational controls.

---

4. IMPLEMENTATION DETAILS AND ATTACK ANALYSIS

4.1 Initial Attack Surface

The initial attacks were associated with Equifax online dispute portal. The application allowed consumers to submit documents and information related to disputes involving the credit reports. According to the GAO, the attack gained unauthorized access to this portal through the internet.

The application used purchase struts, which contain the vulnerability CBE 2017 5638.

4.2 Vulnerability Disclosure and Patch Failure

The Apache software foundation in a security update of CVE-2017-5638 available on March 7, 2017 on .March 8, the United States computer emergency readiness team notified facts about the need to pass the vulnerability. Equifax subsequently distributed an internal notification, instructing the person responsible for Apache struts installations to locate their software.

Equifax patching policy required critical vulnerability to be addressed within 48 hours. However, the vulnerable Paache stress component in the online dispute portal was not identified by the organisation scanning process and remains unmatched.

This was a critical point in the incident because the organisation had received information about vulnerability before attackers gained access.

4.3 Reconnaissance and Initial Access

On March 10, 2017, attackers scanned Equifax systems to determine whether they were vulnerable to the newly disclosed Apache struts vulnerability. The attackers identified a server associated with Equifax online dispute port.

The attacker subsequently exploited the vulnerable applications and gained the ability to execute command on the compromise, the initial compromise provided a foothold from which further activities could be conducted inside the Equifax environment.

4.4 Internal Discovery and Database Access

After obtaining access to the compromise system, the attackers began investigating the internal environment. They issued commands and queries to identify systems containing valuable information.

According to the GAO, attackers used existing and encrypted communication channels associated with the online dispute portal to send commands and retreat personally identifiable information from other systems. The attackers also discovered a repository containing PII as well as username and passwords that could provide access to additional Equifax databases.

This stage demonstrates why internal segmentation and least privilege access are important. The compromise of an internet facing application should not automatically allow restricted access to databases containing highly sensitive information.

4.5 Credential Exposure

The discovery of insecurity stored credentials significantly increased the potential impact of the initial compromise. The attackers were able to use credentials found within the environment to access additional databases.

The FTC reported that the attackers found administrative credentials stored in plain text. This illustrates that a vulnerability in an application can become a much larger incident and authentication credentials are not adequately protected.

4.6 Data Collection and Exfiltration

The attacker searched databases for personal information and retrieved data from systems containing consumer records. The information included names, date of birth, Social Security numbers, addresses and other personal information. The FTC later reported that approximately 147 million people were affected by the breach.

The GAO reported that attackers used encrypted communication channels while interacting with compromise systems. This helped build their activity. Blend with a legitimate tribute network, traffic and meet detection are more difficult.

The Incident demonstrates that encryption alone does not indicate legitimate activity. Security monitoring must also examine behaviour, access patterns and unusual data movement.

4.7 Detection and Response

Equifax security team detected a suspicious traffic network associated with the online dispute portal on July 29, 2017. The suspicious traffic was investigated and blocked. Additional suspicious activities were detected on July 30 after which the affected web application was taken off-line.

On August 2, Equifax engaged Mandian to conduct a forensic investigation. The company also contacted the FBI investigation that was used to determine the scope of the intrusion and identify the information that has been accessed.

Delayed discovery illustrates the importance of continuous security monitoring. According to the house investigation and GOA material, the attacks were able to remain within the environment for an extended period before the suspicious activity was identified.

---

5. RESULTS AND DISCUSSION

5.1 Scale and Nature of the Breach

The Equifax breach affected at least 145.5 million individuals according to the GAO; later, FTC settlement material described the affected population as 147 million people. The exposed information included names, date of birth, Social Security numbers, addresses, and other personal information.

The FTC also reported that payment card information relating to approximately 209,000 individuals were affected. The sensitivity of this information made the incident particularly

serious. Unlike ordinary passwords, may personal identity cannot simply be replaced after exposure, consequently, the effects of such breach can continue long after the original incident.

5.2 Analysis of Security Failures

The Equifax incident demonstrates that the initial software vulnerability was only one part of the overall problem, the GAO identified major areas that contributed to the hackers ability to access the network and extract information, identification, detection, segmentation and data governance.

1. The first major issue was identification. Equifax had been notified of the Apache struts Wal, but the affected application was not identified as vulnerable. Subsequences scan also failed to detect the vulnerable component.
2. The second issue was detection and expiration. Digital certificate affected monitoring of traffic associated with the compromise environment, reducing Equifax ability to observe the attackers activity,
3. Third involves segmentation. Once the attack compromised the internet facing application, they were able to access additional internal data bases. This increases the amount of information that could potentially be stolen.
4. The Fourth issue involves data governance credential protection. The attackers discovered credentials that allow them to access additional systems and databases containing sensitive information.

These failures demonstrate the concept of defence in depth. Multiple independent security controls had functioned effectively. The exploitation of a purchase struts vulnerability would not necessarily have resulted in access to such a large volume of sensitive information.

Security Area	Observed Failure	Security Impact
Patch Management	The Apache Struts vulnerability was not patched promptly after notification.	Enabled attackers to exploit the vulnerable application.
Vulnerability Management	A vulnerable internet-facing application remained exposed.	Allowed attackers to gain initial access to the network.
Network Segmentation	Internal systems were not sufficiently isolated.	Increased the possibility of unauthorized access to sensitive databases.
Credential Security	Administrative credentials were stored in plaintext.	Made it easier for attackers to obtain credentials and access protected resources.
Security Monitoring	An expired digital certificate affected the ability to inspect network traffic.	Reduced monitoring effectiveness and contributed to delayed detection.
Incident Response	The breach was detected months after the vulnerability was disclosed.	Allowed attackers to maintain access and potentially extract more data.

5.3 Organizational Impact

The breach resulted in significant financial and legal consequences for Equifax in 2019. The Lost Federal trade commission announced a settlement under which Equifax agreed to pay at least $575 million and potentially up to $700 million in connection with the breach.

The incident also caused substantial reputational damage for an organisation whose business depends heavily on the collection and management of consumer information. Loss of public confidence represents a significant long-term consequence.

The incident also resulted in increased regulatory attention towards consumer reporting agencies and their cyber security practices. The GAO subsequently examined federal oversight and security requirements relating to consumer reporting agencies.

5.4 Security Implications

The most important security implication of the Equifax case is that vulnerability management must be measurable and very fireable. Organisations should not consider a vulnerability resolved because the patch has been announced for an employee to have been inducted to install it.

A mature security program should maintain an accurate inventory of assets and software, identify vulnerable components, prioritise critical vulnerability, deploy patches, and verify premeditation.

The case also demands the importance of limiting the impact of successful exploitation of network segmentation, at least privilege access, secure, credential storage database, access, controls, and continuous monitoring, and prevent in attack of whom is one application from reaching large amounts of sensitive data.

---

6. SECURITY RECOMMENDATIONS

The Equifax incident provides several recommendations for organisations handling sensitive information.

The first requirement is a complete and continuously updated asset inventory. Organisations should know which hardware operating system. Application frameworks and software components are deployed across your environment. This allows security teams to determine whether newly discovered vulnerability affect their system–

Patch management should be treated as a complete life-cycle rather than a simple installation task. Critical vulnerability should be prioritised. Patches should be deployed within determined time frames and successful installation should be independently. Verified automated vulnerabilities scanning can provide an additional layer of assurance.

Network architecture should follow the following principles of at least privilege. Internet facing applications should not have unnecessary access to sensitive databases segmentation can ensure compromise of one system does not automatically expose. Entire environment.

Credentials must be securely managed, administrative credentials should not be stored in plain text and should be protected using appropriate secret management and access control mechanisms. Strong authentication and regular credential. Rotations can further reduce the risk.

Security monitoring should be continuous organisations, monitor, traffic, network, authentication, events, database, access, and point activity and the health of security infrastructure itself, certificates, monitoring agents and logging system should be checked regularly to ensure that security controls remain operational.

Finally, organisations should maintain and regularly test incident responsive procedures. A well prepared response. Teams can identify suspicious activity, isolate compromise systems, reserve evidence and reduce time attacks that remain inside the environment.

---

7. CONCLUSIONS

The Equifax data breach of 2017 demonstrates how unknown software vulnerability can develop into a major cyber security incident. When combined with weaknesses and organisational security controls the vulnerability involved a part struts CVE-2017-5638 for which a security update was available before the attackers successfully compromise EP fax system.

The breach was not simply the result of a failure to install a software update, the investigation revealed a broader set of weaknesses involving vulnerability, identification, network segmentation, credential protection, monitoring, and data governance. Once attackers gain access to the vulnerable applications. These weaknesses allow them to access additional systems and databases containing sensitive consumer Information.

The case highlights importance of defence in-depth organisations must assume that individual security controls can fail and should therefore implement multiple independent layers of protection, accurate asset, inventories, timely patching, least privilege access, network segmentation, secure credentials, continuous monitoring, and effective incident response can significantly reduce the impact of a successful attack.

The Equifax reach ultimately demonstrates that cyber securities are not sold as a technical responsibility. It requires effective policies, processes, technology, monitoring management, oversight, and accountability for organisations responsible for sensitive people. Information cyber security must be treated as a continuous organisational process, rather than one time implementation.

7. REFERENCES

[1] U S Government Accountability Office, Data Protection: Actions Taken by Equifax and Federal Agencies in Response to the 2017 Breach, GAO-18-559, 2018

[2] U S House of Representatives, Committee on Oversight and Government Reform, The Equifax Data Breach, 2018

[3] Federal Trade Commission, “Equifax to Pay $575 Million as Part of Settlement with FTC, CFPB, and States Related to 2017 Data Breach,” 2019

[4] Apache Software Foundation, “Response From The Apache Software Foundation to Questions From US House Committee on Energy and Commerce Regarding Equifax Data Breach,” 2017

[5] Apache Software Foundation, “Apache Struts Security Advisory: CVE-2017-5638,” 2017

[6] National Institute of Standards and Technology, “National Vulnerability Database: CVE-2017-5638,” NIST

[7] National Institute of Standards and Technology, Cybersecurity Framework 2 0, 2024

[8] National Institute of Standards and Technology, Computer Security Incident Handling Guide, Special Publication 800-61

[9] National Institute of Standards and Technology, Guide to Enterprise Patch Management Planning, Special Publication 800-40

[10] National Institute of Standards and Technology, Security and Privacy Controls for Information Systems and Organizations, Special Publication 800-53

[11] National Institute of Standards and Technology, Zero Trust Architecture, Special Publication 800-207, 2020

[12] National Institute of Standards and Technology, Guide to General Server Security, Special Publication 800-123

[13] OWASP Foundation, OWASP Top 10: The Ten Most Critical Web Application Security Risks

[14] OWASP Foundation, Application Security Verification Standard

[15] OWASP Foundation, Software Component Verification Standard

[16] Center for Internet Security, CIS Critical Security Controls Version 8

[17] International Organization for Standardization, ISO/IEC 27001: Information Security Management Systems — Requirements

[18] International Organization for Standardization, ISO/IEC 27002: Information Security Controls

[19] Verizon, Data Breach Investigations Report, Verizon Business

[20] IBM Security, Cost of a Data Breach Report

[21] European Union Agency for Cybersecurity, ENISA Threat Landscape

[22] U S Department of Homeland Security, US-CERT Alert on Apache Struts Vulnerability CVE-2017-5638, 2017

[23] U S Securities and Exchange Commission, Cybersecurity Risk Management, Strategy, Governance, and Incident Disclosure

[24] Federal Trade Commission, Data Security Guidance for Businesses, FTC

[25] Apache Software Foundation, Apache Struts Security Documentation

[26] Romanosky, S , "Examining the Costs of Cyber Incidents," Journal of Cybersecurity, Vol 2, No 2, 2016

[27] Anderson, R and Moore, T , "The Economics of Information Security," Science, Vol 314, No 5799, 2006

[28] Gordon, L A , Loeb, M P , and Zhou, L , "Investing in Cybersecurity: Insights from the Gordon-Loeb Model," Journal of Information Security, 2011

[29] Singer, P W and Friedman, A , Cybersecurity and Cyberwar: What Everyone Needs to Know, Oxford University Press, 2014

[30] Stallings, W and Brown, L , Computer Security: Principles and Practice, Pearson

[31] Whitman, M E and Mattord, H J , Principles of Information Security, Cengage Learning

[32] Kshetri, N , "Privacy and Security Issues in Cloud Computing," Journal of Global Information Technology Management, 2013

[33] CISA, Known Exploited Vulnerabilities Catalog, Cybersecurity and Infrastructure Security Agency

[34] CISA, Vulnerability Management Guidance, Cybersecurity and Infrastructure Security Agency

[35] SANS Institute, Incident Response and Computer Forensics Resources, SANS Institute

[36] European Union Agency for Cybersecurity, Incident Response and Cybersecurity Guidance, ENISA